

다양한 인증 요소를 활용한

AI 기반 무자각 지속 인증

목차 CONTENTS

무자각 지속인증 프레임워크 제안

PART 01



위협 분석 및 현황

Slide 03 - 06

PART 02



정책 배경 및 요구사항

Slide 7 - 13

PART 03



인증 기술 진화

Slide 14 - 26

PART 04



무자각 지속인증 프레임워크

Slide 27 - 34

PART 05



도입 효과 및 적용 전략

Slide 35 - 42

PART

01

위협 분석 및 현황

Threat Analysis & Current Status

✓ 자격증명 침해 사례

✓ 자격증명 공격 통계

01

자격증명 침해 사례

Credential abuse case

자격증명 탈취로 인한 대규모 개인정보 침해사고가 지속하여 발생하고 있습니다.

크리덴셜 스텔핑 (Credential Stuffing)



대기업 쇼핑몰 (2025/01)

**25 및 **샵 계정 대상 대규모 대입 공격 발생, 약 9만 5천 건, 158만 건의 개인정보 유출. 단일 로그인 인증의 취약점 악용.



인터넷 강의 포털 (2024/01)

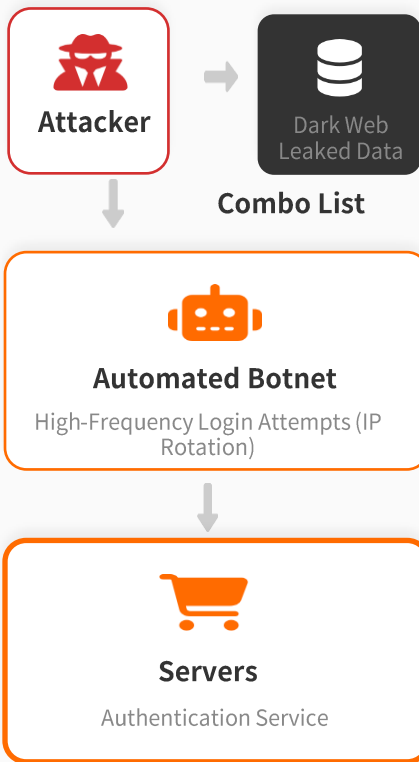
인터넷 강의 사이트 대상 공격 9만 5천 명 개인정보 유출. 로그인 성공 후 XSS 취약점을 연계하여 관리자 권한까지 위협.



공공 취업 중계 사이트(2023/07)

공공 취업 중계 사이트 대상 개인 이력정보 약 23만 건 탈취. 장시간 공격 탐지 실패 사례로 이후 추가인증 확대.

ATTACK MECHANISM



자격증명 관리부실 (Credential Management Failures)



쇼핑몰 계정 탈취 (2025/11)

퇴사자가 반납하지 않은 내부 시스템 접근용 '서명키(Key)'를 이용해 정상 사용자로 위장. 로그인 절차 없이 고객 데이터에 접근.



통신용 인증서 탈취 (2025/09)

24만 대의 펌토셀이 모두 동일한 인증서를 사용하고 관리되는 허점을 이용. 이 인증서를 탈취·복제하여 내부 코어망에 무단 접속.



공공 인증서 탈취 (2025/07)

PC 악성코드에 감염되어 650여건의 GPKI 인증서 유출. G-VPN에 로그인하여 3년간 자료 열람.



Cause & Effect Analysis



자격증명 관리 부실

Credential Mismanagement

Weak PW

Hardcoded Key

Phishing



인증 수단 도용 및 접근

Unauthorized Access via Stolen Creds

"System identifies attacker as a Valid User"



침해 사고 발생

Data Breach & System Compromise

× Data Leakage

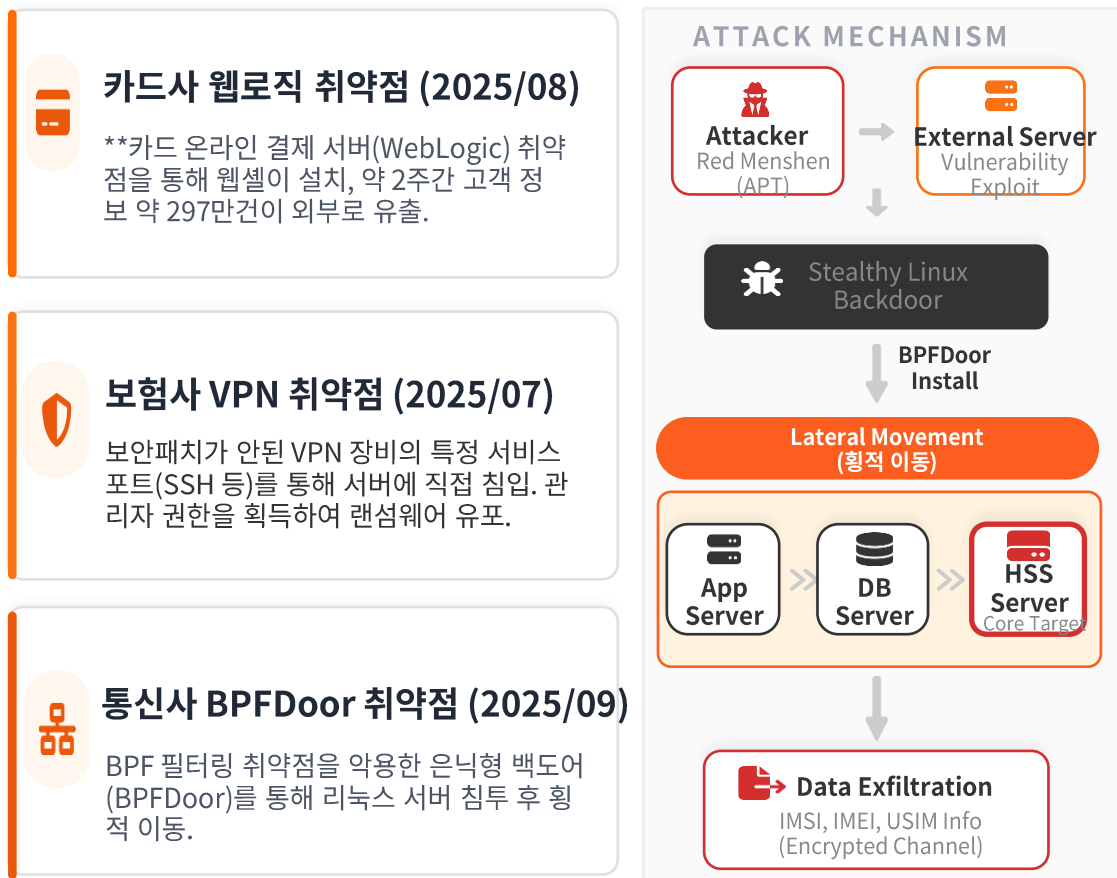
× Lateral Movement

자격증명 침해 사례

Credential abuse case

취약점을 이용한 자격증명 우회사고가 지속되고 있으며, 고수준 생체정보 인증 우회 기술 또한 증가하고 있습니다.

취약점 침투 (Vulnerability Exploitation)



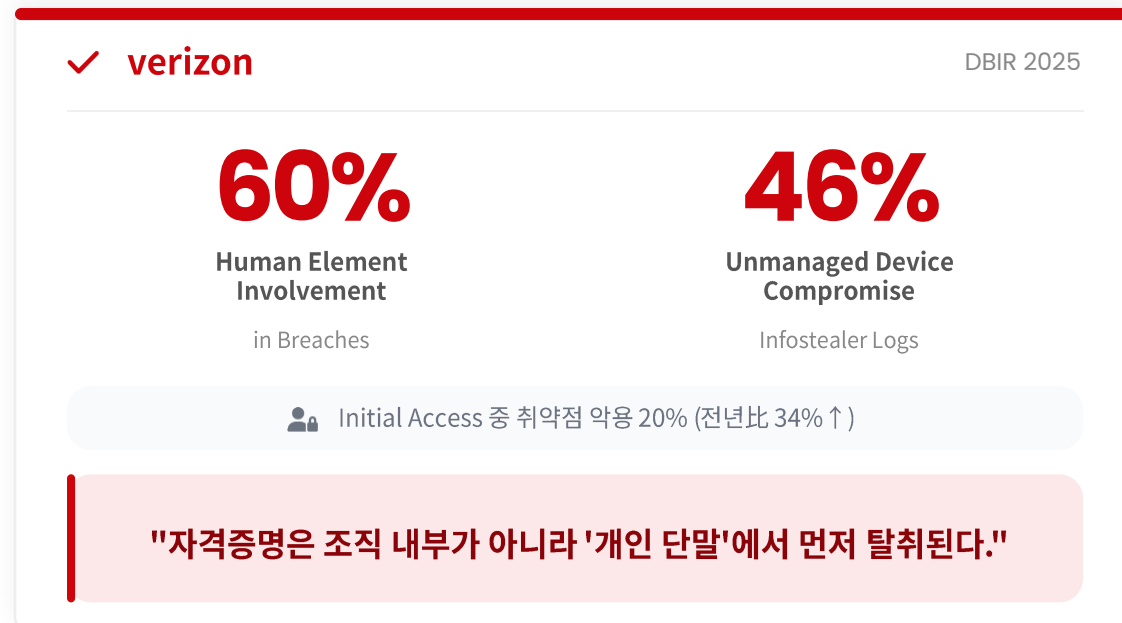
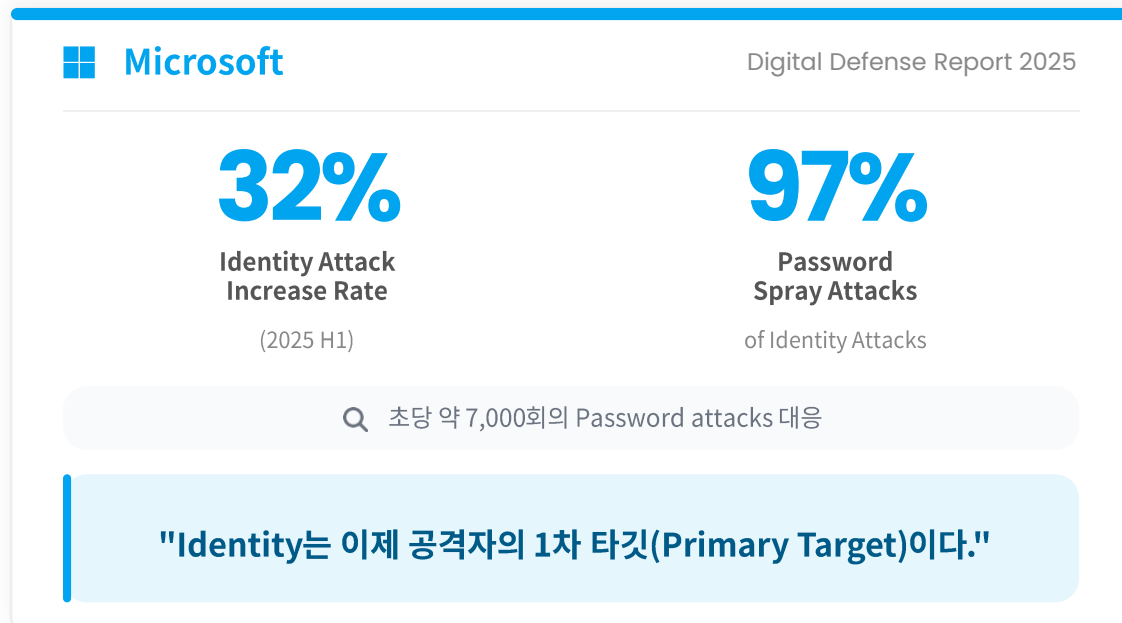
AI 합성 공격 (AI Synthesis Attack)



자격증명 공격 통계

Credential Attack Statistics

각종 통계를 통해 자격증명 탈취 공격의 지속적인 증가를 확인 할 수 있습니다.



패스워드 공격 + 인포스틸러 + 피싱 → 자격증명 지속 유출·재사용

"로그인 시점 1회 MFA만으로는 세션 탈취·후속 이상행위를 충분히 통제하기 어려움."

- ❌ Static Trust (Login-Time Only)
- ⚠️ Session Hijacking Risk
- ➡️ Need Continuous Verification

PART

02

정책 배경 및 요구사항

Policy Background & Requirements

- ✓ 제로트러스트 Identity 요구사항
- ✓ 국가 망 보안 체계(N²SF) Identity 요구사항
- ✓ 제로트러스트·국가 망 보안 체계 공통 요구사항
- ✓ 기술적 패러다임 변화

제로트러스트 인증 요구사항

Zero Trust Identity Core Requirements

제로트러스트 인증 핵심 요구사항으로, 지속인증과 위험도 평가를 강조하고 있습니다.

"Never Trust, Always Verify"

"보호할 자원에 접근하려는 모든 주체에 대하여 신뢰를 부여하지 않고, 지속적으로 검증해야 한다."

사용자·단말·세션 상태를 지속적으로 평가하여 동적인 접근 통제를 수행하는 보안 모델

출처: 제로트러스트 가이드라인 2.0 (KISA, 2024.12) (*식별자/신원 성숙도 모델)
제로트러스트 성숙도 모델 해설 (KISA, 2025.12)

제로트러스트 핵심 요구사항



인증 (Authentication)

지속적인 신원 검증 (최적화 성숙도)

로그인 시점의 1회성 인증이 아니라, 세션 전체 동안 사용자·단말·행위 정보를 종합하여 지속적으로 신원을 검증하고 신뢰 수준을 재평가함.



위험도 평가 (Risk Assessment)

AI 기반 실시간 사용자 행동 분석을 통한 위험도 결정 및 지속적 보호 (최적화 성숙도)

사용자 행위(Behavior), 접속 환경(Context), 단말 정보 등을 통합 분석하여 실시간으로 위험도를 산정하고, 위험 수준에 따라 인증 강화 또는 접근 통제를 동적으로 수행함.



가시성 및 분석 (Visibility & Analytics)

속성·사용자·개체 행동 분석(UEBA) 기반 중앙 집중 가시성 확보 (최적화 성숙도)

사용자 및 개체(Entity)의 속성과 행위를 통합 분석하여 이상 행위를 탐지하고, 중앙 집중화된 모니터링 체계를 통해 지속적인 보안 가시성과 추적성을 확보함.

제로트러스트 인증 요구사항

Zero Trust Identity Core Requirements

성숙도 모델 향상/최적화 단계에서는 선택적 MFA, 실시간 지속인증, AI기반 행동 분석 등을 요구합니다.

제로트러스트 성숙도 모델 (인증 부문)

		 다중인증(MFA)	 지속 인증	 행동, 컨텍스트 기반 및 생체 인식
설명		사용자 시스템 접근 시 2개 이상의 인증 방법을 요구. MFA와 IDP 도입에 초점. 성숙도가 높아짐에 따라 대체 가능하고 유연한 MFA 방식을 적용하여 내/외부 사용자 접근 제공.	지속적인 속성 기반 인증(Continuous Attribute-Based Authentication)으로 이동. 초기 단일 인증 표준화 후, 시간 기반 규칙 인증 추가 및 응용/SW 활동 기반 지속 인증으로 발전.	사용자 행동 패턴, 상황 정보를 생체 데이터와 활용하여 인증/접근제어 강화. UEBA를 활성화하고 PAM 및 JIT/JEA 시스템과 통합하여 이상행위 및 악의적 활동 탐지.
성숙도	기존	패스워드와 단순한 MFA(SMS, 이메일)가 같이 적용되어 있는가?	세션 기반 인증이 수행되는가? 사용자의 행동 및 접속 상태 모니터링이 가능한가?	기본적인(지문, 얼굴인식) 생체 인식 기술 적용? 사용자 행동 패턴이 수동으로 분석되는가?
	초기	인증 앱, 하드웨어 토큰 등 다양한 MFA가 구현되어 있는가? FIDO 기반 인증 기법이 적용되어 있는가?	이상행위가 탐지되면 세션 중간에 추가 인증하는 시스템이 도입되어 있는가?	행동 및 생체 인식 기술을 통합하여 인증 가능한가? 컨텍스트 정보 기반 접근권한이 조정되는가?
	향상	상황에 따른 맞춤형 MFA 지원? 컨텍스트(단말, 위치, 네트워크, 접속 시간 등)를 고려한 ID 인증 방식이 적용되어 있는가?	동적 인증 기술을 토대로 실시간 인증 상태에 대한 조정이 가능한가?	실시간 사용자 행동 및 컨텍스트 변화 반영으로 접근제어 조정이 가능한가?
	최적화	비정상적 로그인 시도를 실시간으로 탐지하고 대응 가능한가?	이상 행위 발생 시 자동 재인증 요구, 세션 종료 등 인증 지속적 검증이 실시간으로 가능한가?	AI 기반 행동 분석 및 생체 인식 솔루션이 도입되어 있는가?

국가 망 보안 체계(N²SF) 인증 요구사항

N²SF Identity Policy Core Requirements

국가망 보안체계 인증 핵심 요구사항으로, 사용자 행동분석(UEBA), 위험기반 분석 등을 요구합니다..

POLICY OVERVIEW

기밀성·중요도 기반 차등 통제 체계

New Framework

"기밀성·중요도 기반 차등(C/S/O) 통제 및 지속 검증 체계 전환"

출처: 국가망보안체계(N²SF) 보안 가이드라인 1.0 (2025.09)
(부록1)보안통제 항목 해설서

국가 망 보안 체계 인증관련 주요 요소



속성 기반 접근통제 (ABAC)

환경 기반 조건 평가(위치, 시간 등)를 통해 보안 통제를 차등 적용 권한



계정 이상 행위 탐지 (UEBA)

사용자 및 개체 행동 분석을 통한 이상 행위 실시간 탐지 및 이상 권한 요청 모니터링



다단계 신원 검증 (Multi-Factor Identity Proofing)

안면 + 행위 결합 등 다중 요소를 활용하여 신원 검증을 강화



위험 기반 접근 제어 (Risk-based Access Control)

접속 환경(시간, 장소, 장치 등) 변화 시 위험도에 따라 추가 신원 검증 요구

국가 망 보안 체계(N²SF) 인증 요구사항

N²SF Identity Policy Core Requirements

보안 통제 항목 중 선택적 MFA, 주기적 재인증, 행위 기반 탐지, 연속인증 등을 요구합니다.

국가 망 보안 체계 인증관련 보안 통제 항목

ID	등급	통제 항목 및 설명
N2SF-LP-M2	C S	주요 사용자 위험 관리 주요 사용자의 권한과 활동을 모니터링하고 이상 징후를 탐지하여 위험을 사전에 관리한다.
N2SF-AC-3	C S	의심스러운 계정 모니터링 비정상적이거나 의심스러운 계정 접속 시도 및 활동을 지속적으로 모니터링한다.
N2SF-AC-M3	C S	세션 감사 세션 활동을 기록하고 주기적으로 감사하여 비정상적 행위를 탐지한다.
N2SF-MA-4	C S O	다중요소 인증(MFA) 경로 분리 다중요소 인증시에는 인증을 요청한 장치의 통신 경로와 분리된 별도의 통신 경로를 통해 인증을 수행한다.
N2SF-MA-5	C S	특정상황에서의 다중요소 인증 특정 상황 또는 조건에서는 다중요소 인증을 적용하여 사용자 인증.
N2SF-AU-4	C S O	생체인증 공격 방지 생체 데이터를 암호화하여 저장 및 전송하며, 변조 여부를 탐지할 수 있는 메커니즘을 사용한다.

ID	등급	통제 항목 및 설명
N2SF-AP-4	C	재인증 주기적 또는 특정 상황·조건에서는 사용자에게 재인증을 요구한다.
N2SF-LI-M1	C	로그인 실패 모니터링 및 보고 반복 실패, 의심 로그인 시도 등의 실패 패턴을 실시간 감지하고 관리자에게 보고한다.
N2SF-LI-M2	C S	주기적 로그인 정보 무결성 점검 로그인 관련 데이터(세션, 토큰 등)에 대해 주기적으로 무결성을 점검하고 이상 여부를 확인한다.
N2SF-SN-7	C	세션 중 행위 기반 비정상 탐지 세션 중 사용자 행위가 정상 범위를 벗어나면 자동으로 세션을 종료하거나 별도 인증 절차를 유도한다.
N2SF-SN-8	C S	세션 중 연속 인증 수행 장시간 세션 또는 민감 작업 수행 시, 주기적 또는 조건 기반으로 인증 수단을 다시 요구한다.

제로트러스트·국가 망 보안 체계 인증 공통 요구사항

ZT·N²SF Integration

두 정책 모두 지속적 검증, 상황/행동 기반 인증, 동적 제어 등을 요구하고 있습니다.

Zero Trust 2.0

제로트러스트 가이드라인 2.0

① 지속적 검증

로그인 이후에도 AI가 세션 전체에 걸쳐 신원을 지속적으로 검증하며, 단발성 인증의 한계를 극복

② 상황 인지 기반

생체(얼굴), 행동(타이핑·마우스), 환경(위치·디바이스) 데이터를 결합하여 입체적으로 판단

③ 최소 권한 & 동적 제어

신뢰 점수(Trust Score) 하락 시 즉시 권한을 회수하거나 재인증을 요구하는 동적 제어 수행



국 N²SF

국가망보안체계

① 지속적 신원 검증

로그인 시점뿐 아니라 세션 유지 중에도 사용자 행위를 지속적으로 모니터링하여 검증

② 상황 기반 리스크 평가

사용자·위치·행위 정보를 종합하여 동적으로 위험도를 재평가하고 등급별 통제 적용

③ 엄격한 세션 관리 및 재인증

비정상 행위 감지 시 즉시 세션을 차단하거나 재인증(Re-authentication)을 요구

인증은 '절차'가 아니라 '상태 관리'이다

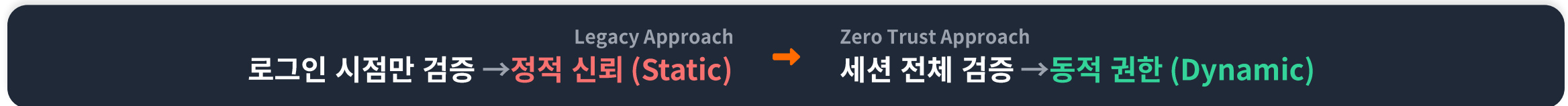
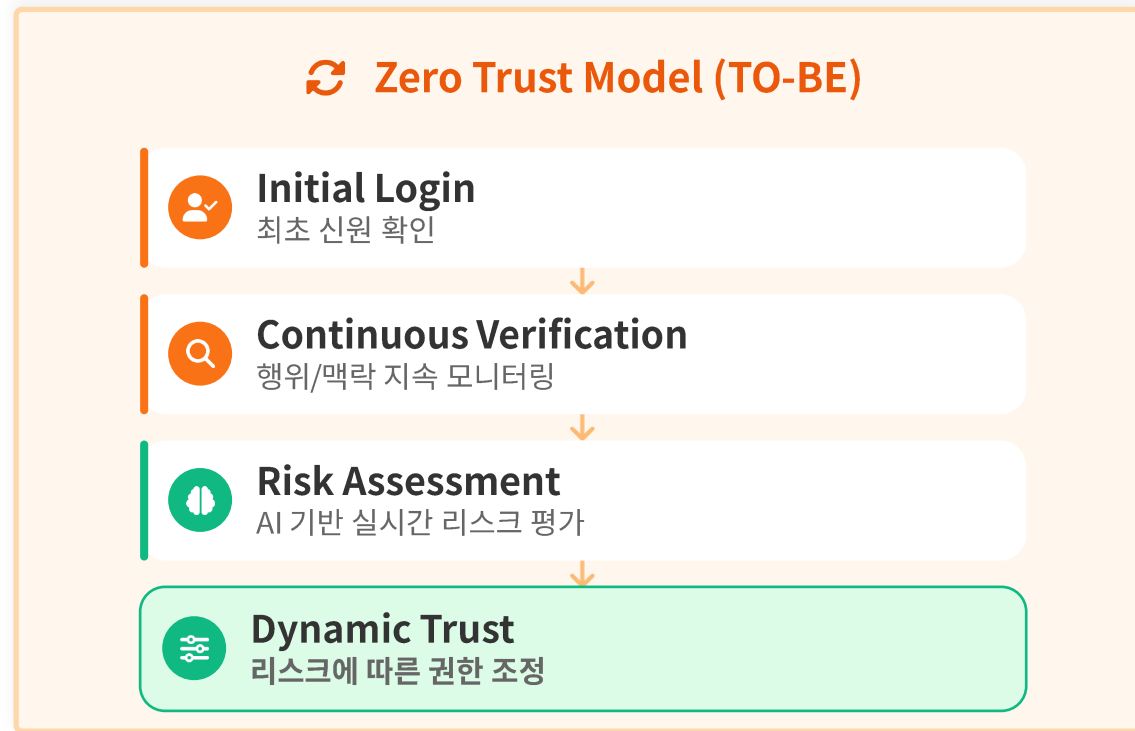
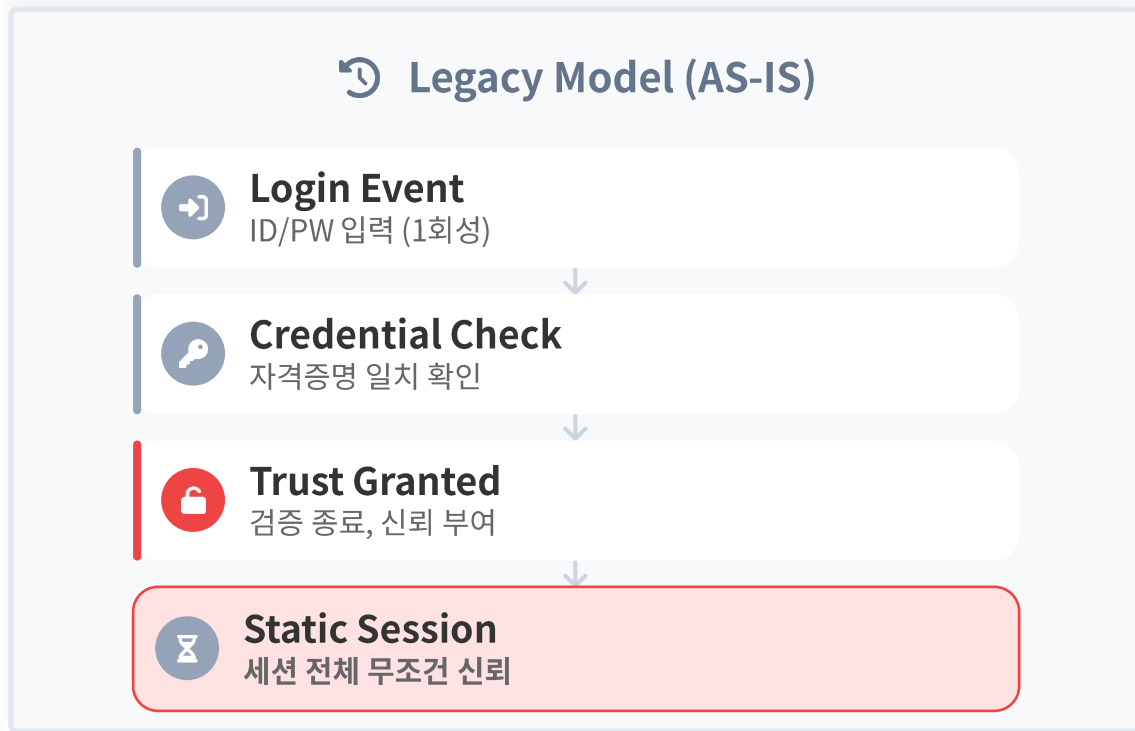


단발성 인증(One-time Event)에서 지속적 검증(Continuous State Monitoring)으로의 전환이 필수

기술적 패러다임 변화

Technical Paradigm Shift

정적, 단일 지점 신뢰 기반에서 세션전체 검증의 동적 평가 및 제어를 요구합니다.



PART

03

인증 기술 진화

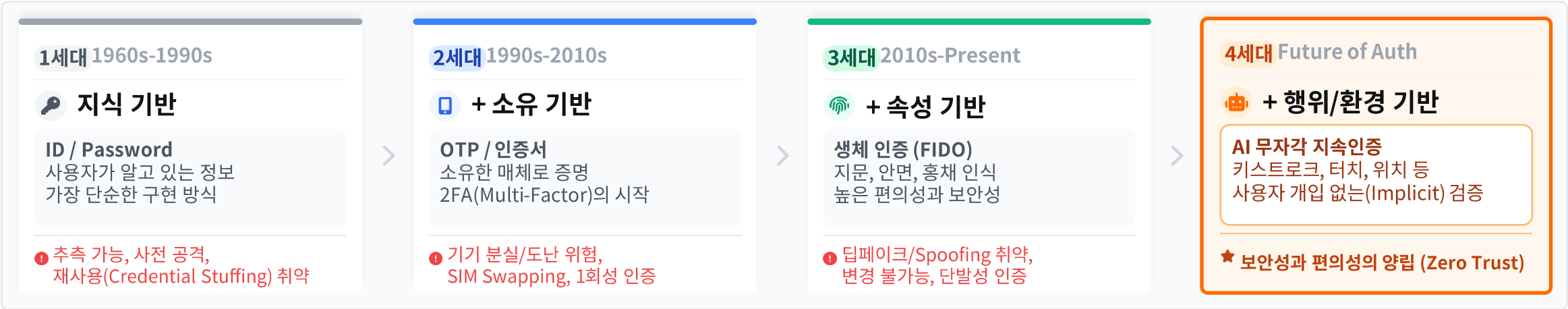
Authentication Technology Evolution

- ✓ 인증 기술 4세대 진화
- ✓ 1~3세대 인증의 한계
- ✓ 4세대 AI 행위/환경 인증
- ✓ 얼굴/음성 인증 기술
- ✓ 키스트로크/터치 행위 인증 기술
- ✓ 위치 기반/근접 인증 기술
- ✓ 기술 성숙도 및 사용자 개입 비교

인증 기술 4세대 진화

Authentication Evolution Timeline

사용자 개입 없이 환경과 행동을 검증하는 4세대 무자각 지속인증으로 인증 기술이 진화하고 있습니다.



세대	구분	주요 기술	사용자 경험 (UX)	주요 보안 한계	보안 강도
1세대	지식 (Knowledge)	패스워드, PIN, 패턴	기억 부담, 입력 불편	Brute Force, Phishing, Reuse	Low
2세대	+ 소유 (Possession)	OTP, SMS, 스마트카드	매체 소지 필수, 분실 우려	Man-in-the-Middle, SIM Swap	Medium
3세대	+ 속성 (Inherence)	지문, 안면, 홍채 (FIDO)	인식 행위 필요 (Touch/Look)	Spoofing, Deepfake, Replay	High
4세대	+행위/환경 (Behavior/Context)	무자각 지속 인증 (AI)	Zero Friction (무자각)	Mimicry Attack(행동모방공격), Adversarial ML(적대적ML공격)	High

* 본 구분은 인증요소(Factor) 중심의 개념적 진화 모델임.

1~3세대 인증의 한계

Legacy Auth Limitations

기존 1~3세대 단일 시점 인증은 세션 탈취 및 자격증명 재사용 공격에 구조적으로 취약합니다.

 1세대  2세대 **Critical Vulnerability**
자격증명 유출, 분실 위험

 3세대 **Critical Vulnerability**
편의성은 높지만, 유출 시 복구 불가



1세대: 지식 기반 (Knowledge-Based)

ID/Password는 추측 가능하며 사전 공격(Dictionary Attack)에 취약.
유출된 자격증명은 재사용(Credential Stuffing) 위험이 매우 높음.



AI 합성 공격, PAD 위험

생성형 AI 기술로 고도화된 안면/음성 합성을 통해 생체 인증 우회.
고해상도 사진, 3D 가면, 녹음된 음성 등을 이용한 기만 공격(Spoofing)에 취약.



2세대: 소유 기반 (Possession-Based)

OTP/인증서는 기기 분실 또는 탈취시 위험이 있음.
SIM Swapping을 통해 SMS 인증 문자 가로채기 가능.



변경 불가능성

비밀번호와 달리 생체 정보는 변경할 수 없음.
한 번 유출되면 영구적인 보안 위협이 됨.



공통 한계: 단일 시점 인증 (Point-in-Time)

기존 1~3세대 인증 방식은 '단일 시점 검증(Point-in-Time)'이라는 공통된 구조적 한계를 가지고 있으며,
로그인 이후 세션 전체에 걸친 지속적 검증이 부재하여 Session Hijacking, Credential Stuffing, Deepfake 등 고도화된 공격에 취약함.

4세대 AI 행위/환경 인증

4th Gen AI Behavior/Context Auth

사용자의 고유한 행위와 환경 정보를 AI로 분석하는 무자각 지속인증 패러다임으로 전환이 필요합니다.



행위 기반 (Behavior)

- 키스트로크 다이내믹스
- 터치 압력 및 궤적
- 마우스 이동 패턴
- 걸음걸이(Gait) 분석



환경 기반 (Context)

- 정밀 실내/실외 위치
- 접속 시간 및 빈도
- 기기 근접성(Bluetooth)
- 네트워크 신뢰도



AI 학습 (Intelligence)

- 사용자 프로파일 학습
- 이상 징후 실시간 탐지
- 동적 위험 평가(Scoring)
- 적응형 정책 자동화

∞ 무자각 지속인증 (Implicit & Continuous)



무자각 (Implicit)
사용자 개입 없이
자동 검증



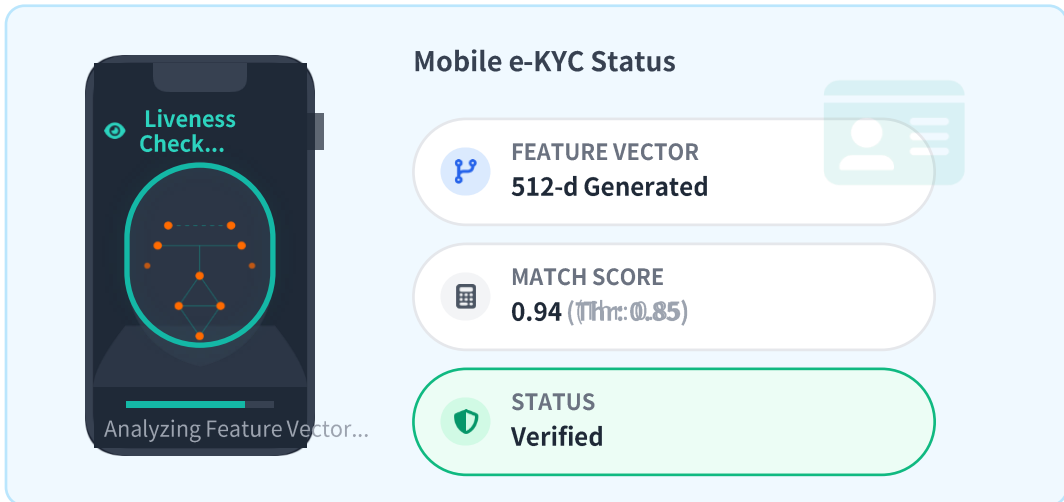
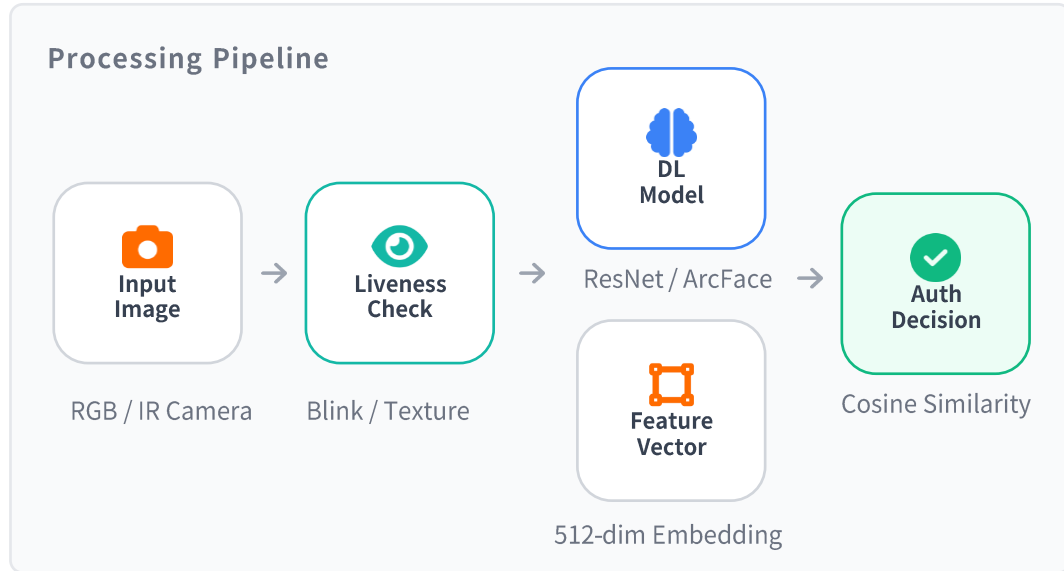
지속성 (Continuous)
세션 전체 구간
실시간 모니터링



위변조 어려움
고유 행위 패턴은
복제 어려움



적응형 (Adaptive)
상황별 동적
보안 강도 조정



얼굴 인증 기술

Facial Recognition Technology

심층 신경망(CNN) 기반의 특징 추출을 통해 조명, 각도, 표정 변화에 강건한 인증을 수행합니다. 특히 최신 모델은 **Feature Vector** 간의 **Cosine Similarity**를 계산하여 높은 정확도를 보장합니다.

✓ Accuracy

99.x% ~

* LFW 벤치마크, 통제된 환경

≡ EER

~1.0%

1:1 Verification, 공개 벤치마크 기준

✓ Liveness Detection Rate

95%+

* 2D/Replay 공격 시나리오 한정.(ISO 30107-3 Framework)

ISO/IEC 30107-3



성능은 데이터셋, 평가 프로토콜(절차), 그리고 운영 임계값에 따라 달라집니다.
벤치마크(평가 기준): LFW, IJB-C, ISO/IEC 30107-3 평가 프레임워크

얼굴인증 알고리즘별 FNMR 성능 분석

Comparative Analysis of FNMR (False Non-Match Rate) by Algorithm

Last Updated: 2026-02-15

알고리즘 / Date (Algorithm)	통제 환경					비통제 환경
	정면사진 : 정면사진	정면사진 : 정면사진 (12년 이상)	비자사진 : 출입국 사진	비자 각도 45도 : 특정각도 출입국사진	출입국사진 : 출입국사진	출입국사진 : 키오스크사진
FMR (False Match Rate)	0.0010%	0.0010%	0.0001%	0.0001%	0.0001%	0.0010%
a****-009 / 2024-11-14	0.26%	0.29%	0.22%	3.23%	51.94%	58.65%
c****-004 / 2024-12-05	0.25%	0.27%	0.23%	1.20%	0.44%	4.23%
f****-002 / 2025-02-11	0.24%	0.22%	0.36%	0.43%	0.93%	9.00%
m****-003 / 2023-04-04	0.26%	0.36%	0.28%	2.30%	24.11%	34.44%

출처 <https://pages.nist.gov/frvt/html/frvt11.html>

f****-002, c****-004

Best Overall

가혹 환경에서도 균형 잡힌 성능

조명/각도 비제어 환경 등에서도 낮은 에러율로 균형잡힌 성능 제공

비통제 환경 에러율4.23~ 9.0%

a****-003, m****-003

Vulnerable

환경 변화에 치명적 성능

통제된 환경 및 출입국사진 환경에서 성능 보장 불가.
24.11%~58.6% 이상 실패.

비통제 환경 에러율58.65%

얼굴인증 위변조 탐지

Face Spoofing Detection

↔ Active → Passive 전환

2025 Market Report에 따르면 **Passive** 솔루션이 빠르게 성장하고 있으며, 주요 글로벌 벤더들이 모두 Passive 기술에 집중 투자 중입니다.



Deepfake & GenAI 대응

고품질 딥페이크와 3D 마스크 공격 방어를 위해 **Texture Analysis** 및 **Depth Map** 분석 기술 고도화



High Accuracy

(Didit 등 시험 조건 한정) 최대 **99.9% 정확도** 를 달성하여 실시간 위변조 차단 가능



Global Standard Compliance

ISO/IEC 30107-3 표준 준수 및 iBeta Confirmation Letter Level 2/3 필수 확인



NIST FATE & iBeta 제3자 검증

iBeta는 Confirmation Letters를 공개하며, NIST FRTE는 리더보드 형태로 벤더 성능을 투명하게 공개합니다.

객관적 성능 검증 체계

ISO/IEC 30107-3



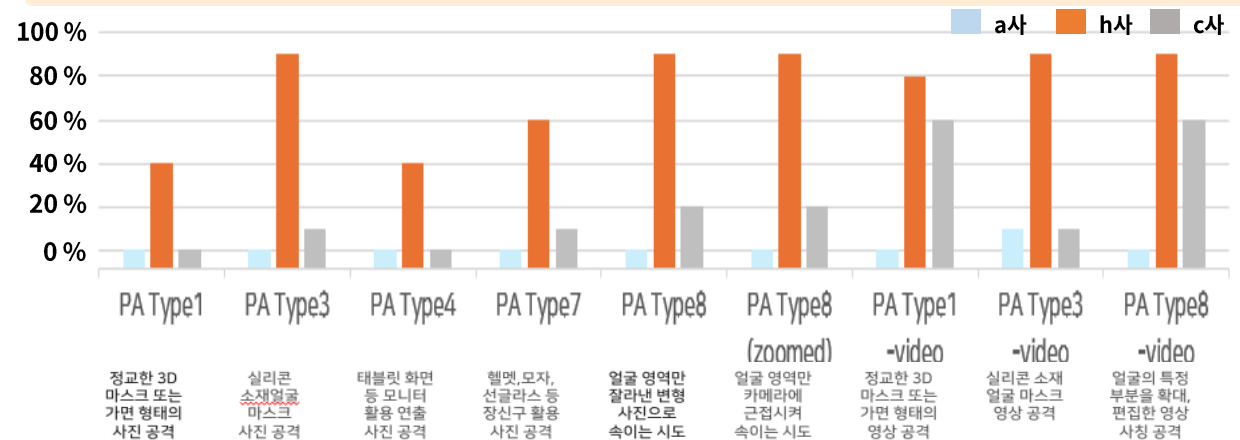
iBeta PAD Test, Confirmation Letter 현황 (2026/02)

Test Level	공격 시료 (Attack Types)	글로벌	국내
Level 1	2D Photo & Video 고해상도 사진, 스마트폰 영상	120+	4
Level 2	3D Mask & Latex 정교한 3D 마스크, 라텍스	70+	1
Level 3	Deepfake & Injection 실시간 딥페이크, 인젝션	1	0

<https://www.ibeta.com/iso-30107-3-presentation-attack-detection-confirmation-letters/>



NIST IR 8491 - Face Analysis Technology Evaluation (FATE) Part 10 (2023/09)



<https://www.nist.gov/publications/face-analysis-technology-evaluation-fate-part-10-performance-passive-software-based>

음성 인증 기술

Voice Authentication

딥러닝 기반 화자 임베딩(x-vector, ECAPA-TDNN)을 이용해 음성 특징을 벡터화하고 등록 화자와의 유사도를 비교하여 식별 합니다. 특히 생성형 AI 위협에 대응하기 위해 **Anti-spoofing**(위변조 탐지) 모델이 필수적으로 결합된 파이프라인을 사용합니다.

⚠ 화자인증(ASV) EER (Equal Error Rate)

1~3%

NIST Speaker Recognition Evaluation (SRE21)
VoxCeleb Benchmark 연구 결과

Core Technology

x-vector

Text-Independent Embedding

🔴 위변조 탐지(CM) EER

3.3~4.3%

ASVspoof5 Track 1 Open 상위권

🔴 통합 성능(SASV) t-EER

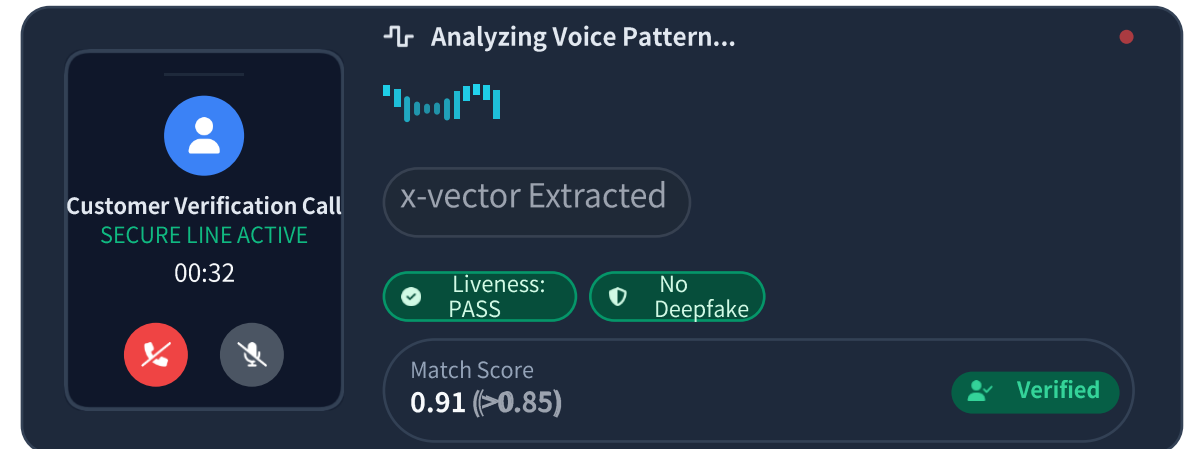
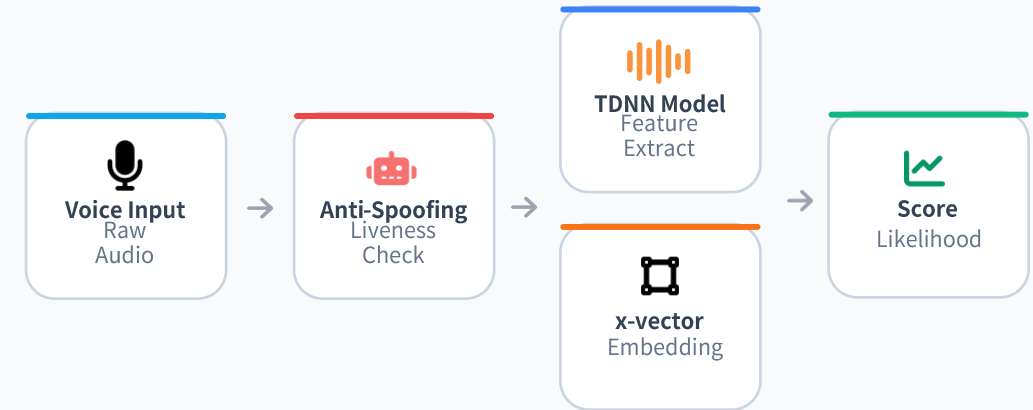
2~4%

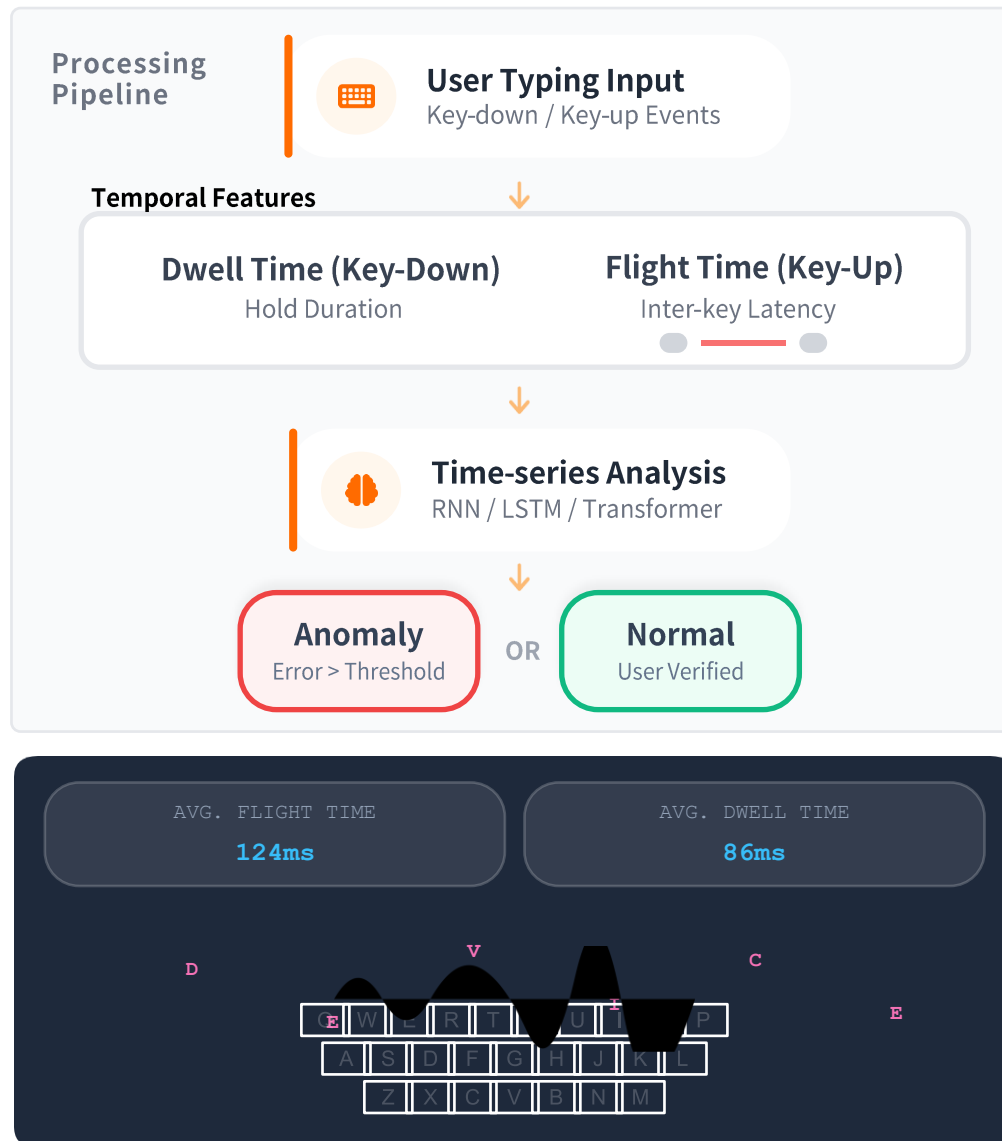
ASVspoof5 Track 2 Open top-1 기준.
min a-DCF(attack Detection Cost Function)
) ≈ 0.07 .

🏠 NIST SRE & ASVspoof 제3자 검증

ASVspoof5 결과 리포트 : <https://arxiv.org/pdf/2601.03944>
NIST SRE21 결과 리포트 : <https://arxiv.org/pdf/2204.10242>

Processing Pipeline





키스트로크 행위 인증

Keystroke Dynamics

사용자의 타이핑 리듬을 분석하는 무자각 인증 기술입니다.

Inter-keystroke latency(비행 시간)와 **Dwell time**(누름 시간)을 **LSTM** 으로 시계열 분석하여, 별도의 입력 행위 없이 본인 여부를 지속적으로 검증합니다.

🎯 EER(Equal Error Rate)

2.2~9.6%

Physical keyboard

🧠 Core Algorithm

LSTM + RNN

Sequence & Anomaly Detection

🔑 Key Analysis Features

Flight Time | Dwell Time | Key Sequence

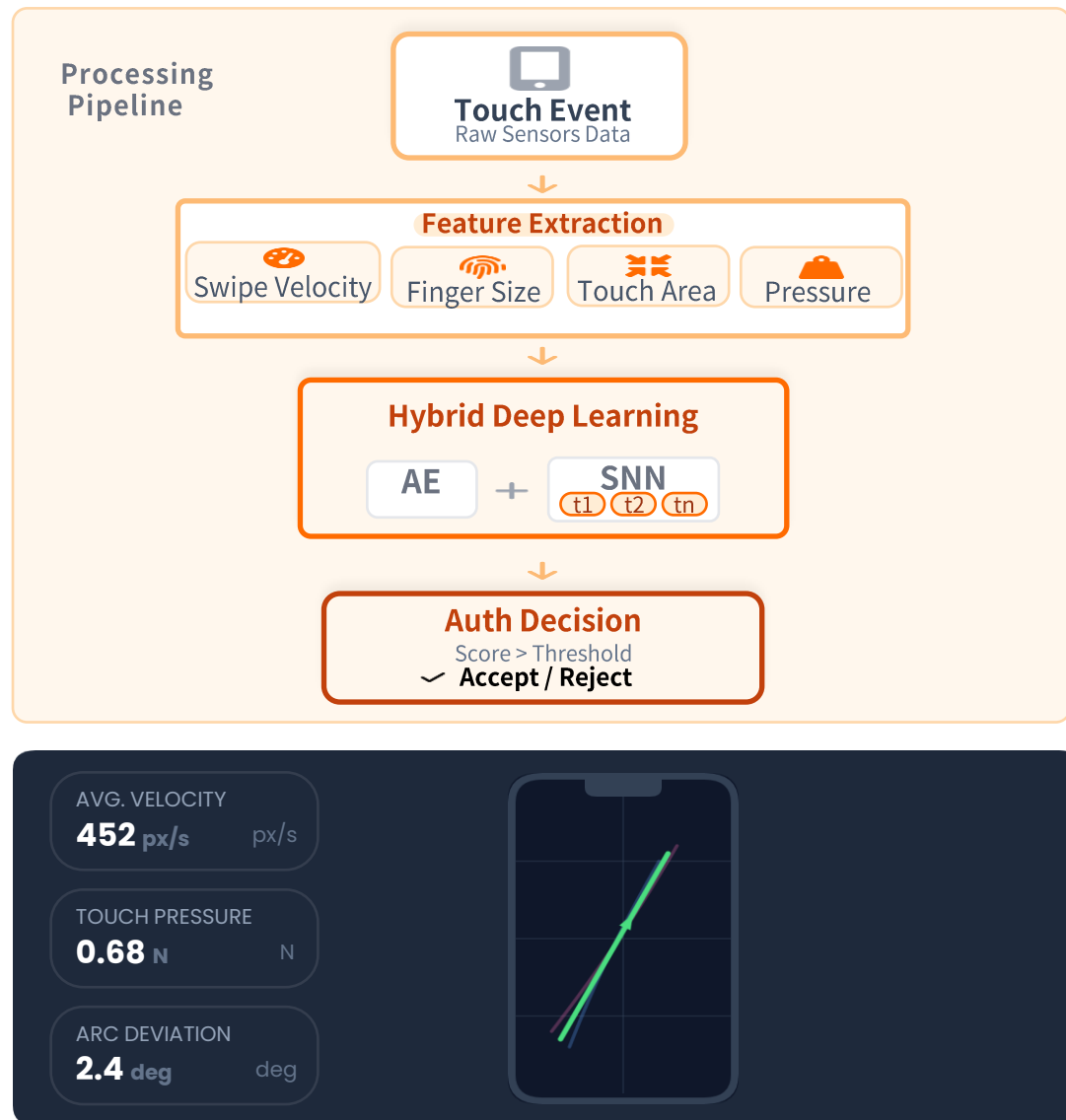
Captures micro-patterns invisible to human eye

Continuous

📖 Key References

TypeNet: Deep Learning Keystroke Biometrics (2021)

Comparing Anomaly-Detection Algorithms for Keystroke Dynamics (2009)



터치 행위 인증

Touch Dynamics

사용자가 스마트폰을 조작할 때 발생하는 **Swipe 속도**, 누르는 **압력(Pressure)**, 터치 면적 등을 정밀하게 분석합니다.

AE(Autoencoder, 정상 패턴 학습)와 **SNN(Siamese Neural Network, 패턴 유사도 비교)**이 결합된 구조를 통해, 사용자별 고유한 터치 행동 패턴을 학습하고 동일 사용자 여부를 판별합니다.

🕒 EER(Equal Error Rate)

4.8%~9.85%

🏗 Architecture

SNN + AE

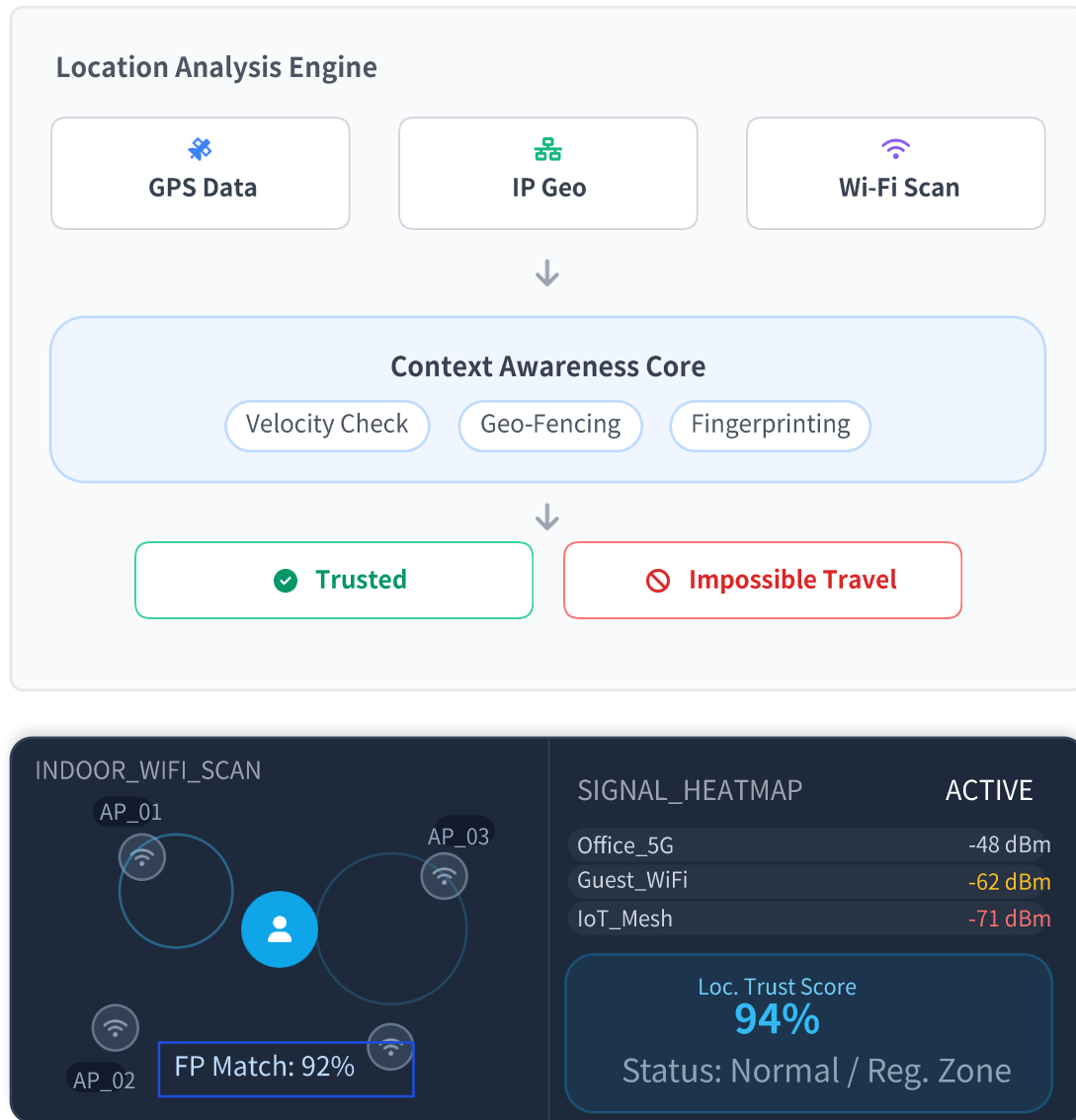
Hybrid Deep Learning

📊 Key Features Analyzed

속도	압력	접촉 면적	접촉 크기
Velocity	Pressure	Touch Area	Size

📖 Key References

Techniques for Continuous Touch-Based Authentication (2022)
A Framework for Continuous Authentication Based on Touch Dynamics Biometrics for Mobile Banking Applications (2021)



위치 기반 인증

Location-based Auth

사용자의 물리적 위치(Location)와 이동 속도(Velocity)를 분석하여 비정상적 접근을 탐지합니다. GPS, IP 주소, Wi-Fi 신호 정보를 결합하여 실외뿐 아니라 실내 위치까지 정밀하게 검증합니다.

Wi-Fi Fingerprinting

3 ~ 10m

Indoor Positioning Accuracy (Ideal: 1-2m)



Geo-velocity Detection

Detects Impossible Travel
(e.g., >1,000km/h movement)



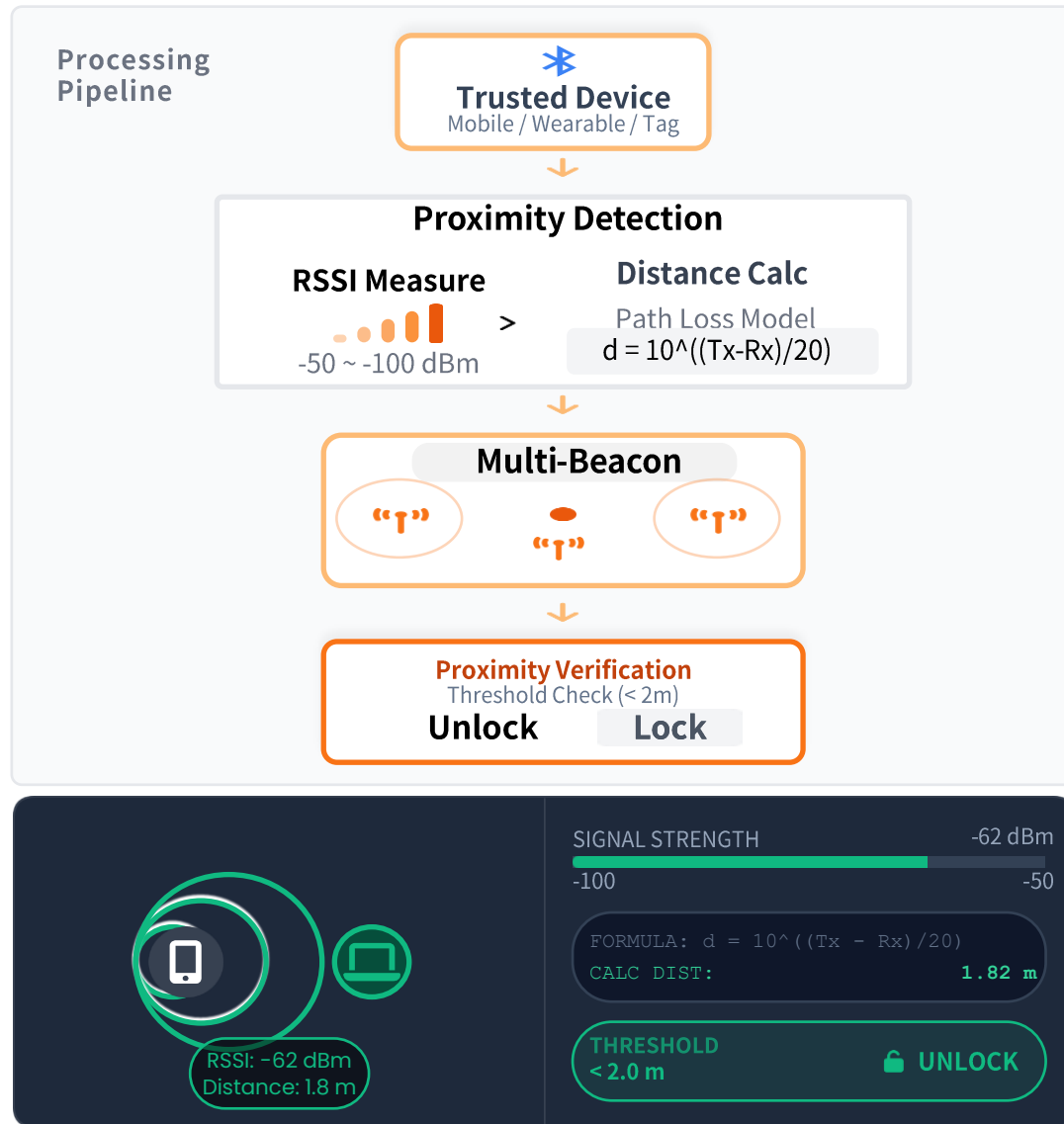
IP Reputation Filter

Blocks Tor, VPN, Proxy IPs based on
Global Threat Intelligence DB



Use Case

주로 최초 접속 시점의 신뢰도 평가나, 장거리 이동이 감지될 때 Step-up 인증을 트리거하는 용도로 활용됩니다.



근접 인증 기술

Proximity Authentication

사용자가 소지한 **신뢰 기기(Trusted Device)**의 **Bluetooth RSSI(신호 강도)**를 측정하여 물리적 근접 여부를 판단합니다.

단순히 '연결' 여부가 아닌, '거리 기반'의 실시간 분석을 통해 자동 잠금/해제 (Auto-Lock/Unlock)를 수행하여 보안성과 편의성을 동시에 제공합니다.

Distance Accuracy

수 m 수준(환경 의존)

Standard BLE (RSSI)

RSSI Range

-50~-100

dBm (Signal Strength)

Next-Gen Precision

Sub-meter (<1m)

Bluetooth 6.0 Channel Sounding

표준화 완료
생태계 확산 중

Technical Standards

RSSI Analysis: Log-distance path loss model for proximity estimation
Anti-Relay: Detecting signal boost attacks via latency checks

기술 성숙도 및 사용자 개입 비교

Technology Maturity Comparison

다양한 인증 요소를 사용하여 무자각 지속인증 프레임워크를 구성할 수 있습니다.

기술 구분 (Technology)	정확도 (EER)	사용자 개입 (Friction)	지속 가능성 (Continuous)	PAD 저항 (Anti-Spoofing)
 얼굴 인증 Passive  Background Check	~1.0% (Good)	낮음(Low)	높음 (High)	높음 (High)
 음성 인증 Passive  Free Speech	3% (Medium)	낮음(Low)	중간 (Medium)	중간 (Medium)
 Keystroke Dynamics  Behavioral Biometrics	2~10% (Low)	없음 (None)	최상 (Best)	높음 (High)
 Touch Dynamics  Behavioral Biometrics	5~10% (Low)	없음 (None)	최상 (Best)	높음 (High)
 Wi-Fi (Location)  Context Aware	Support	없음 (None)	높음 (High)	낮음(Low) ~ 중간 (Medium)
 Bluetooth (Proximity)  Context Aware	Support	없음 (None)	높음 (High)	낮음(Low) ~ 중간 (Medium)

“ 다양한 인증요소를 명시적 사용자 행동 요구 없이 무자각 상태에서 지속적인 신원 검증 수단으로 사용합니다. ”

PART

04

무자각 지속인증 프레임워크

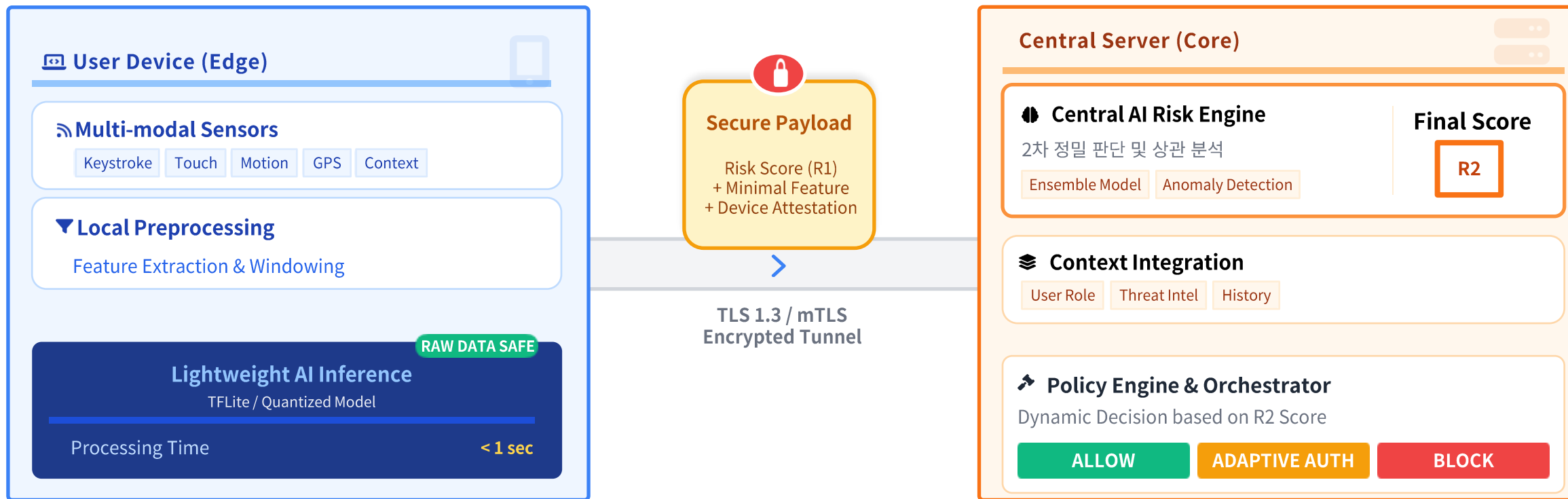
Implicit Continuous Authentication
Framework

- ✓ Edge AI 기반 아키텍처
- ✓ 프레임워크 아키텍처
- ✓ 특징 추출 상세
- ✓ AI 리스크 엔진 모델
- ✓ 인증 강도 레벨 정의
- ✓ 인증 오케스트레이션 의사결정 로직
- ✓ 정책 맵핑

Edge AI 기반 아키텍처

Edge AI-Based Architecture

단말 중심의 1차 위험 판단 구조를 통한 Privacy-First Zero Trust 아키텍처를 구현 합니다.



Raw Data 보호

생체 원본 데이터 외부 전송 최소화



최소 정보 전송

Risk Score 또는 암호화된 비식별 데이터, 해시값만 전달



Privacy-preserving

서버는 사용자 행위 원본 모름



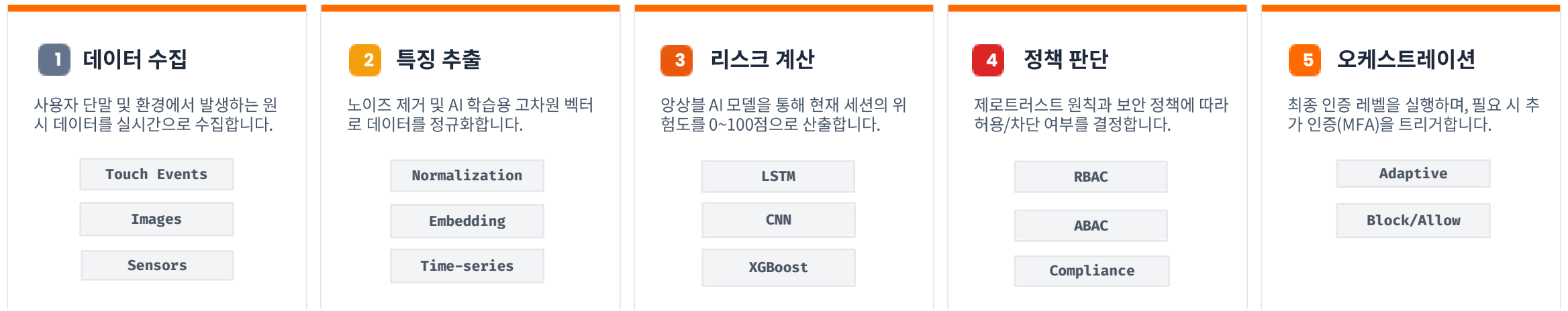
Real-time 처리

목표응답 시간:
엣지 추론으로 1초 미만 응답

프레임워크 아키텍처

Framework Architecture

무자각 지속인증 프레임워크는 5계층 데이터 흐름으로 구현 할 수 있습니다.



특징 추출 상세

Feature Engineering

다양한 비정형 Raw Data를 AI 모델 학습에 최적화된 고차원 벡터(Vector)로 변환하는 핵심 전처리를 수행합니다.

Raw Data Sources



User Actions

Keystroke, Touch, Gyro



Device Info

UserAgent, Battery



Environment

GPS, IP, Wi-Fi List



Video

Face Expr, Gaze, Posture

Preprocessing Engine



Noise Filtering

Remove outliers



Normalization

Min-Max / Z-score



Video Processing

Face Detect / Feature Embedding



Encoding

One-hot / Hashing

Output Feature Vectors



Behavioral Vector

128-dim

Source: 키스트로크(Key-down/up), 터치 좌표(x,y), 압력
Process: Time-difference 계산 → **Z-score Normalization**



Device Fingerprint

64-dim

Source: 기기 고유값(IMEI/UUID), 브라우저/OS 정보
Process: 범주형 데이터 **One-hot Encoding** 및 Feature Hashing



Contextual Metadata

32-dim

Source: GPS 좌표, IP 주소 대역, 접속 시간대(Time of Day)
Process: 연속형 데이터 **Min-Max Scaling**, 위치 정보 Geo-hashing

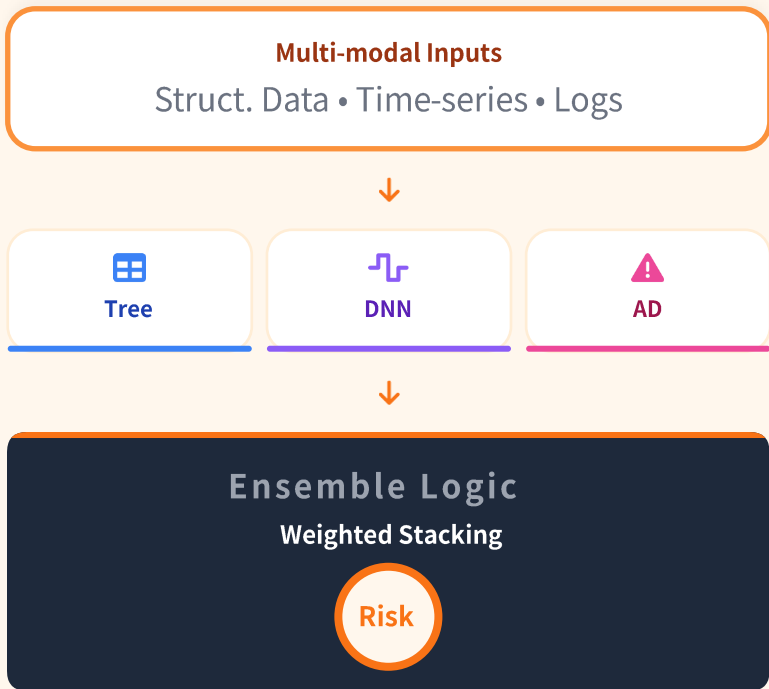


Video Feature Vector

128-dim

Source: 얼굴 랜드마크, 시선, 자세
Process: Face Alignment, Pose Est.

Execution Pipeline



AI 리스크 엔진 모델

AI Risk Engine

서로 다른 데이터 특성에 최적화된 3가지 AI 모델을 앙상블(Ensemble)하여, 단일 모델의 한계를 극복하고 이상 행위 탐지 정확도를 극대화합니다.



Tree-based ML Model

XGBoost / LightGBM

트리 기반 앙상블 모델 : Random Forest, XGBoost 등 다수의 결정 트리(Decision Tree)를 결합하여 접속 위치, 기기 정보, 시간대 등 명확한 속성 (Feature) 기반 패턴을 학습하고 분류합니다.



Deep Neural Network

LSTM / Transformer

시계열 패턴 학습: 마우스 궤적, 키스트로크 타이밍 등 시간 흐름에 따른 연속적인 비정형 행동 데이터를 심층 분석합니다.



Anomaly Detection

Autoencoder

이상 징후 탐지: 정상 패턴(Normal Profile)을 학습하여 재구성 오차가 큰 미확인 공격(Zero-day) 및 비정상 행위를 식별합니다.

인증 강도 레벨 정의

Auth Level Definition

상황 기반 리스크(Contextual Risk)에 따라 동적으로 적용되는 4단계 적응형 인증 레벨을 설계 합니다. .

L3

복합 다중 인증 (Strong MFA)

얼굴(Face)

+

행동(Behavior)

+

환경(Context)

이상 징후
고액 이체, 관리자 접근
(ex, Score >= 100)

L2

FIDO / 생체 인증 (Biometric)

FIDO Key

/

지문

/

App 인증

중요 업무
개인정보 열람, 결제 승인
(ex, 60 <= Score < 100)

L1

지식 기반 인증 (Knowledge)

ID/PWD

/

PIN

/

Pattern

일반 업무
레거시 시스템, 일반 정보 조회
(ex, 최초 로그인시)

L0

무자각 지속 인증 (Continuous Trust)

행동(Behavior)

+

환경(Context)

평소 업무
환경, 등록된 기기
(ex, Score < 30)

NIST SP 800-63B AAL 맵핑

* L0는 AAL을 보완하는 '지속 검증' 계층

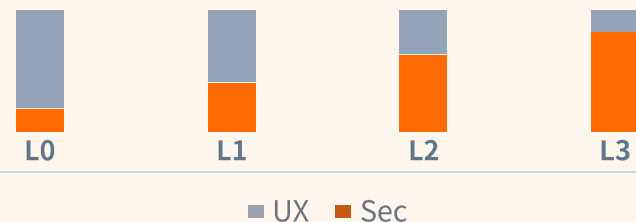
L1 ≈ AAL 1 (Some)

L2 ≈ AAL 2 (High)

* L3 ≈ AAL 3 (Very High)

* AAL 매핑은 참고 예시이며, 실제 AAL3 충족 여부는 비내보내기형 공개키 인증자 적용 여부에 따라 달라짐

UX vs Security Trade-off



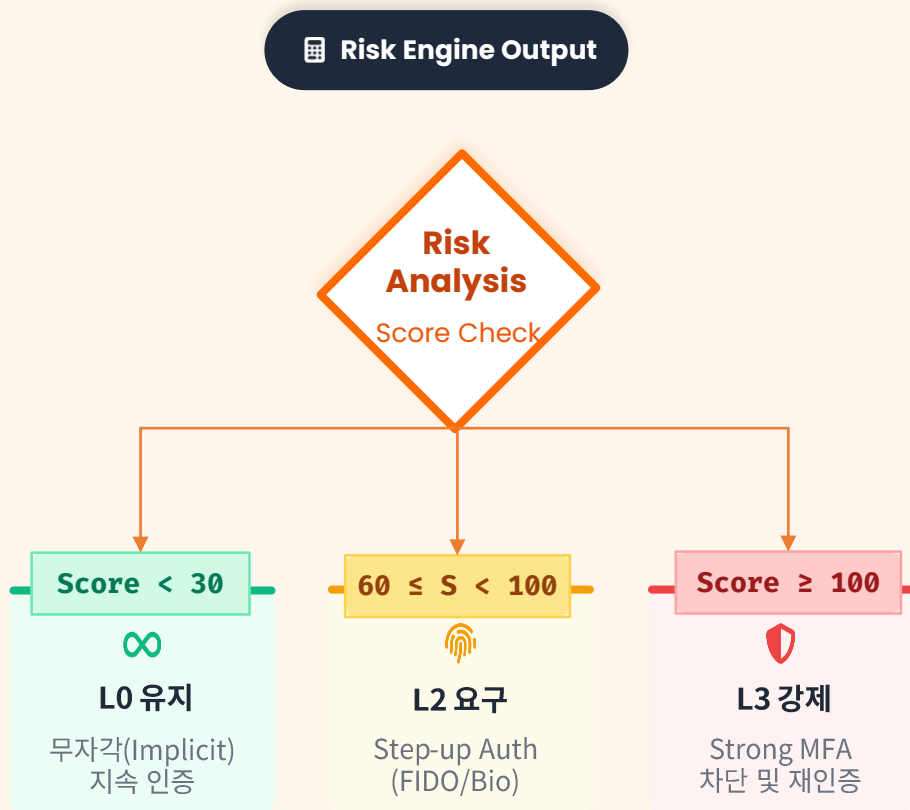
지속 가능성 (Sustainability)

L0 Only

Session-wide Protection

• Always On

Orchestration Flow



인증 오케스트레이션 의사결정 로직

Authentication Orchestration Decision Logic

AI Risk Engine이 산출한 점수에 따라 사용자의 인증 등급을 실시간으로 조정합니다. 보안성과 사용자 편의성(UX)의 최적 균형을 유지하는 핵심 로직입니다.

Threshold 1 : Normal

Score < 30

[유지] 무자각 지속 인증 (L0)

정상 패턴 범위 내. 사용자 개입 없이 백그라운드에서 신뢰 상태를 갱신합니다.

Threshold 2 : Caution

60 ≤ Score < 100

[요구] 생체/FIDO 인증 (L2)

미세한 이상 징후 감지. 중요 트랜잭션 전 본인 확인을 위한 추가 인증을 요청합니다.

Threshold 3 : Critical

Score ≥ 100

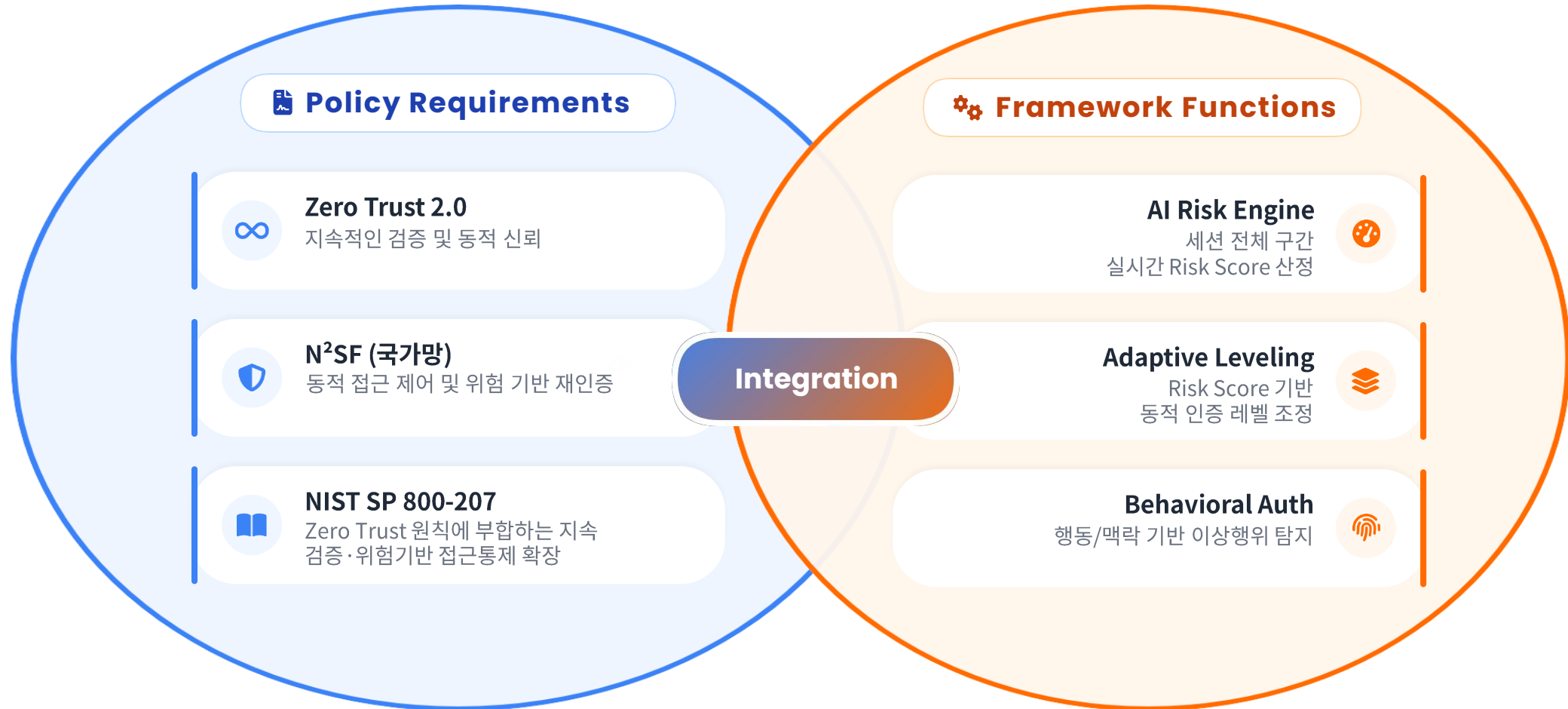
[강제] 복합 다중 인증 (L3)

명확한 위협 탐지. 즉시 세션을 차단하거나, 얼굴+행동 등 강력한 MFA를 강제합니다.

정책 맵핑

Policy mapping

무자각 지속인증 프레임워크의 주요 기능은 Zero Trust, N²SF, NIST 등 주요 보안 정책 요구사항을 만족합니다.



PART

05

도입 효과 및 적용 전략

Business Impact & Adaptive Application

- ✓ 사용자 경험 혁신
- ✓ MFA vs 무자각 지속인증 시나리오 비교
- ✓ UX 측정 지표
- ✓ 산업별 적용 시나리오
- ✓ 환경별 적용 시나리오
- ✓ Zero Trust 통합 아키텍처
- ✓ 기대 효과 및 결론

UX 혁신

UX Innovation

강력한 보안을 유지하면서도 사용자 개입을 최소화 하여 자연스러운 업무흐름을 제공합니다.

기존 MFA의 UX 딜레마

"보안성을 높이면 편의성이 떨어진다?"

전통적인 인증 방식은 보안 강화를 위해 **사용자 개입**을 강제하며, 이는 필연적으로 **UX 저하**를 초래합니다.



Security ↔ Convenience

Critical

보안 강도와 사용자 편의성은 **제로섬(Zero-sum)** 관계입니다. 복잡한 비밀번호와 잦은 변경 요구는 사용자의 불편을 가중시킵니다.



MFA Fatigue (인증 피로도)

High Impact

하루에도 수차례 반복되는 OTP 입력과 생체 인증 요구는 **보안 피로감**을 주며, '보안 불감증'으로 이어질 수 있습니다.



Process Disruption (업무 단절)

Productivity

업무 수행 중 발생하는 갑작스러운 재인증 요구는 **업무 몰입을 방해**하고 조직 전체의 생산성 저하를 유발합니다.

무자각 지속인증 UX 혁신

“보안과 편의성의 양립”

기존의 Trade-off 관계를 극복하고, 강력한 보안을 유지하면서도 사용자에게 **매끄러운 경험(Seamless Experience)**을 제공합니다.



Zero Friction

인증 소요 시간 89% 단축

별도의 인증 행위 없이 **백그라운드에서 자동 인증**을 수행하여 사용자의 업무 몰입을 방해하지 않습니다.



Always-On Security

보안 사고 대폭 감소 효과

최초 로그인 이후에도 세션 전체를 지속적으로 모니터링하여 **실시간 위협을 즉시 탐지**하고 대응합니다.



Seamless Experience

사용자 만족도 40% 증가

인증 절차가 업무 흐름에 자연스럽게 녹아들어, 사용자는 보안이 적용되고 있음을 인지하지 못합니다.

MFA vs 무자각 지속인증 시나리오 비교

MFA vs Implicit Continuous Authentication

무자각 지속인증은 사용자로 하여금 반복적이고 불편한 재인증을 요구하지 않습니다.

기존 MFA (Legacy)

1

로그인 시도
ID/PW 입력 후 접근 요청

2

MFA 요구 (차단)
SMS/OTP 인증 번호 입력 요구

3

대기 및 입력
앱 실행, 번호 확인 및 입력 (약 30~60초 소요)

4

반복적 재인증
세션 만료 시 동일 과정 반복 → 피로도 증가

VS

무자각 지속인증 (Proposed)

1

로그인 (자동화)
위치/기기 기반 무자각 신원 확인

2

백그라운드 분석
행위(키보드/마우스) 패턴 실시간 모니터링

3

신뢰 자동 연장
정상 패턴 유지 시 세션 자동 갱신

4

Adaptive Step-up
이상 징후 감지 시에만 추가 인증 요구

Key Difference

"업무 흐름을 끊지 않는(Seamless) 보안 경험 제공"

User Friction

Zero (90% ↓)

Security Coverage

100% (Continuous)

UX 측정 지표

UX Metrics

무자각 지속인증 도입 전후의 사용자 경험(UX) 개선 효과를 4가지 핵심 지표로 정량화하여 분석했습니다



인증 소요 시간 (Avg. Time)

기존 (Legacy)

Avg. 45초



제안 (Proposal)

< 5초

↓ 89%

로그인 및 2차 인증(MFA)에 소요되는 총 시간 대폭 단축

■ 출처: [Beyond Identity](#) & [Freemindtronic](#) 연구 (전통적 MFA 30-60초, 고급 인증 5-10초)



인증 빈도 (Frequency)

기존 (Legacy)

8회/일



제안 (Proposal)

< 1회/일

↓ 87%

사용자가 하루 동안 수행해야 하는 명시적 인증 횟수 감소

■ 출처: [PMC 8434648](#) (지속 인증으로 명시적 인증 빈도 87% 감소)



사용자 만족도(사내 설문)

기존 (Legacy)

62점



제안 (Proposal)

87점

↑ 40%

보안 절차에 대한 내부 직원 만족도 설문 결과 (100점 만점)

■ 출처: [Avatier 2024](#) (Passwordless 인증 NPS 15-40% 향상)



이탈률 (Drop-off Rate)

기존 (Legacy)

23%



제안 (Proposal)

8%

↓ 65%

복잡한 인증 절차로 인한 프로세스 중도 포기 비율

■ 출처: [LinkedIn](#) & [Prove](#) 연구 (복잡한 MFA 이탈률 20-30%, 고급 인증 10% 이하)

산업별 적용 시나리오

Application Scenarios

금융/공공/국방 등 보다 높은 보안수준을 요구하는 다양한 산업군에 적용이 가능합니다.



금융 서비스 Smart Banking & FDS

💰 이상거래 탐지 시스템(FDS) 연계

- **Normal State**
정상 거래 다수는
L0 무자각 인증 유지
- **Risk Event**
고액 이체 시도 +
위치 변경 감지
- **Action**
자동으로 **L3 (안면인식)** 수행

★ **Expectation**
"보안은 강화하되, UX는 유지"
불필요한 OTP 요구 최소화로 이탈 방지



공공/국방 National Security & N²SF

@ 국가망 보안체계(N²SF) 등급 연동

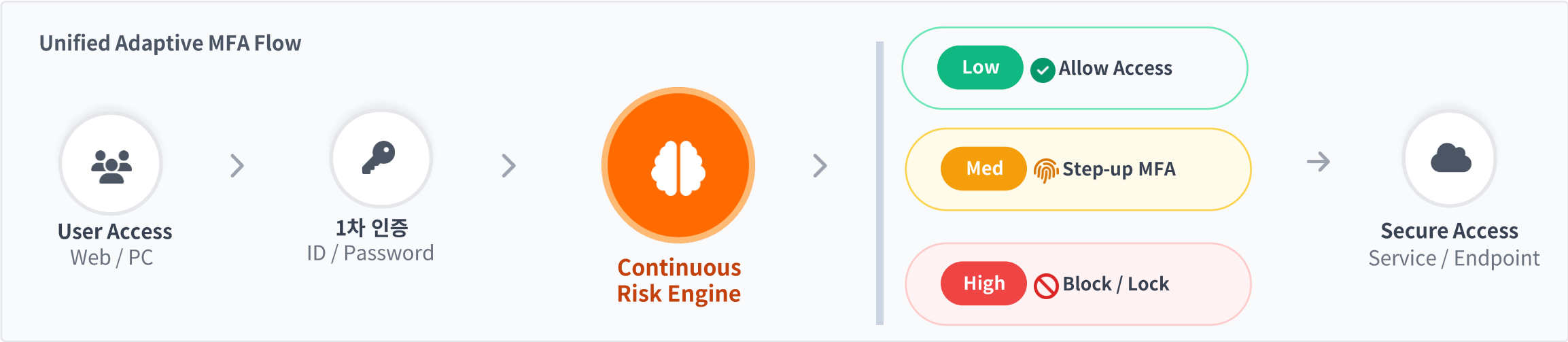
- **In-Office**
청사 내 업무망 접속
L0 접근 허용 (신뢰 IP)
- **Context Change**
외부망 접속 또는
업무 행위 패턴 변화
- **Action**
즉시 등급 재산정 및
추가 인증(L2) 요구

✓ **Expectation**
"정책 기반의 동적 보안 체계"
물리적 망분리 → 논리적 접근통제 전환

환경별 적용 시나리오

Use Cases by Environment

선택적 MFA 서비스는 다양한 웹, CS 환경의 위협을 완화 할 수 있습니다.



Zero Trust 통합 아키텍처

Continuous Trust Architecture

무자각 지속인증 제러트러스트 아키텍처의 중심 역할을 수행하여, 각 도메인의 사용자 신뢰지표를 제공합니다.



기대 효과 및 결론

Conclusion & Impact



보안성 향상

기존 단일 인증 대비 인증 우회 위협 감소

인증 우회 및 세션 악용 탐지·완화 가능성 제고

멀티모달 결합 분석(확률의 곱법칙), 실시간 검증(1초 단위), IEEE 논문(TAR) 인증 차단 99.9%



사용자 편의성 향상

명시적 인증요구 최소화로 편의성 향상

정상 사용자는 무자각 인증 유지, 불필요한 개입 최소화

인증 시간 절감(15-20초→0초), 집중력 유지(UC Irvine), TCO 절감(Gartner 25-30%)

"강력한 보안과 끊임 없는 경험의 공존"

본 프레임워크는 제로트러스트 2.0 (Zero Trust) 및 국가 망 보안 체계 (N²SF)의 핵심 원칙 – 지속 검증, 동적 통제, 위험기반 재평가 – 에 정합 하도록 설계한 지속 인증 프레임워크 입니다.

✓ Zero Trust 2.0 Compliant

✓ N²SF Ready

Hancom xCAuth



끊김 없는 보안, 무자각 지속 인증 플랫폼

The Future of Continuous Authentication

AI 기반 비대면 음성 인증 솔루션

Hancom AISRC SPEEKEY



강력한 위변조 탐지 AI 안면 인증

Hancom Auth



eGISEC 2026 | Booth No. T135

